An AI reference architecture for the enterprise

Key aspects across the enterprise architecture domains

Enterprise Architecture · 4 November 2026

[Insert official FIP signature and Canada wordmark]

1

Why a reference architecture

One set of shared parts and controls, so each AI use case does not start from zero.

One architecture lets every use case reuse controls

— Without one, each project picks its own model, its own data copy and its own safeguards.

— With one, projects plug into a shared gateway, shared knowledge services and a shared approval path.

— It covers generative AI, retrieval, agents and machine learning.

— It is technology-neutral. It names roles (gateway, index, model service), not products.

— It does not replace the solution architecture of any one project. It sets the boundaries each one works inside.

Reading this deck

— Built for reading and printing, not for presenting.

— Each diagram fits a 6.5 in Word column. Select the figure, copy, and paste it as editable shapes.

— Judgment is labelled in the eyebrow. Facts carry sources.

Source: Enterprise Architecture. Judgment: this is my read, not a published standard.

MY READ

Five principles keep the architecture honest

1

Data stays put

Bring the model to the data. Do not copy protected data into new stores.

2

One front door

All model calls pass through one gateway. No direct keys in applications.

3

Rights travel

Access checks follow the user into retrieval and tool calls.

4

People decide

Humans own any decision that affects a client. AI supports it.

5

Swap the model

Models change every few months. Keep them behind a stable interface.

Judgment: this is my read, not a published standard.

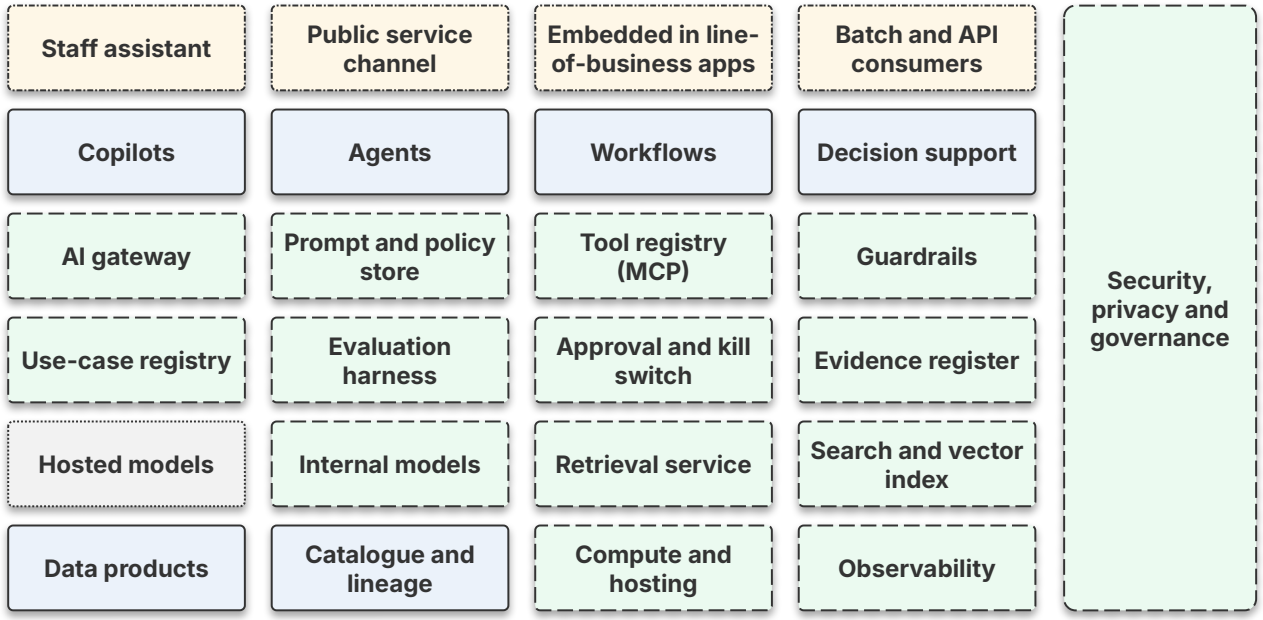
2

The reference architecture

Six layers and one cross-cutting control plane, mapped to the enterprise domains.

MY READ

Six layers share one security and governance plane



Rows: 1 users; 2 applications; 3 gateway; 4 assurance; 5 models and knowledge; 6 data and platform.

Hosted models are the only external box. Calls to them leave through the gateway, never from an application.

Figure 1 — Enterprise AI reference architecture, layered view

How to read it

- Row 1 is who uses AI. Row 6 is what it runs on.
- The gateway (row 3) is the single control point. It is where identity, logging, cost limits and content filters live.
- Row 4 (assurance) is where a use case is registered, tested, approved and evidenced. It can switch a use case off.
- The tall box on the right is a plane, not a layer. It applies to every row.
- Hosted models are dashed and dotted: outside our boundary, so the least trusted.

Source: Enterprise Architecture. Judgment: this is my read, not a published standard.

Each domain owns a different part of AI

Domain	What AI changes	What this architecture fixes	Owner
Business	New channels and new ways to make a decision	Use-case intake and a risk tier before any build	Program area
Data	Documents become a live input to models	Index, do not copy. Classification travels with the data	Data office
Application	Agents call systems on a user's behalf	Agents act only through registered tools	Solution architects
Technology	GPU demand and model hosting choices	Hosting options by data sensitivity (see later slide)	Infrastructure
Security	New attacks: prompt injection, data leakage	Gateway filters, scoped tokens, full call logs	Security
Governance	Output can be wrong yet sound confident	Human review, evaluation and an approval path	AI governance board

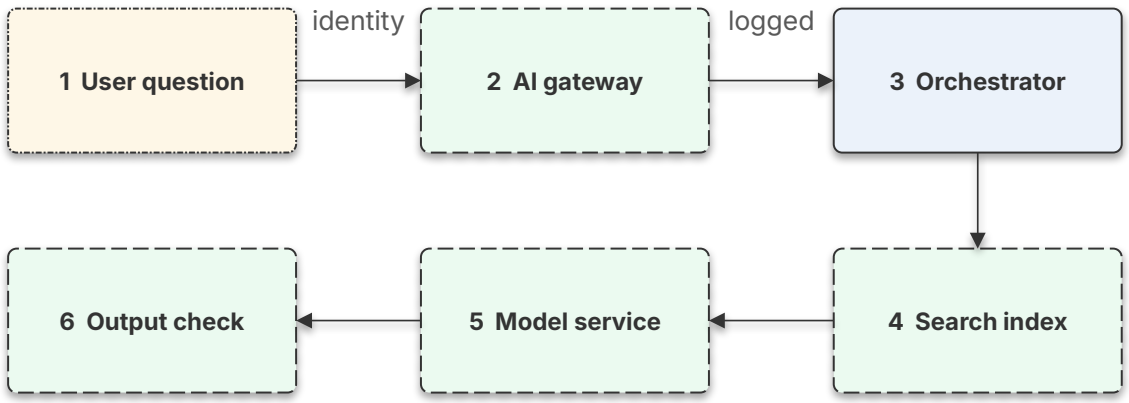
Reading the table

— Domains follow the usual business, data, application, technology split, with security and governance added because AI raises the stakes on both. Owners are suggestions to confirm.

Source: Enterprise Architecture. Judgment: this is my read, not a published standard.

MY READ

A grounded answer checks access at step 4



Step 4: the index returns only passages this user may already read. Rights are checked here, before the model sees anything.
Step 5: the model sees the question plus the retrieved passages, not the whole index.

Step 6: the check looks for leaked identifiers and missing citations. The answer returns to the user through the gateway.

Figure 2 — Retrieval-grounded answer flow

Why this order

— Grounding on our own documents cuts invented answers and lets the answer cite its source.

— Putting the rights check in the index, not the prompt, is the part teams get wrong most often.

— The gateway sees every call, so one log answers the question "who asked what, and what did the model say".

Source: Enterprise Architecture. Judgment: this is my read, not a published standard.

3

Data, agents and hosting

The three design choices that decide how much risk a use case carries.

Model hosting follows data sensitivity

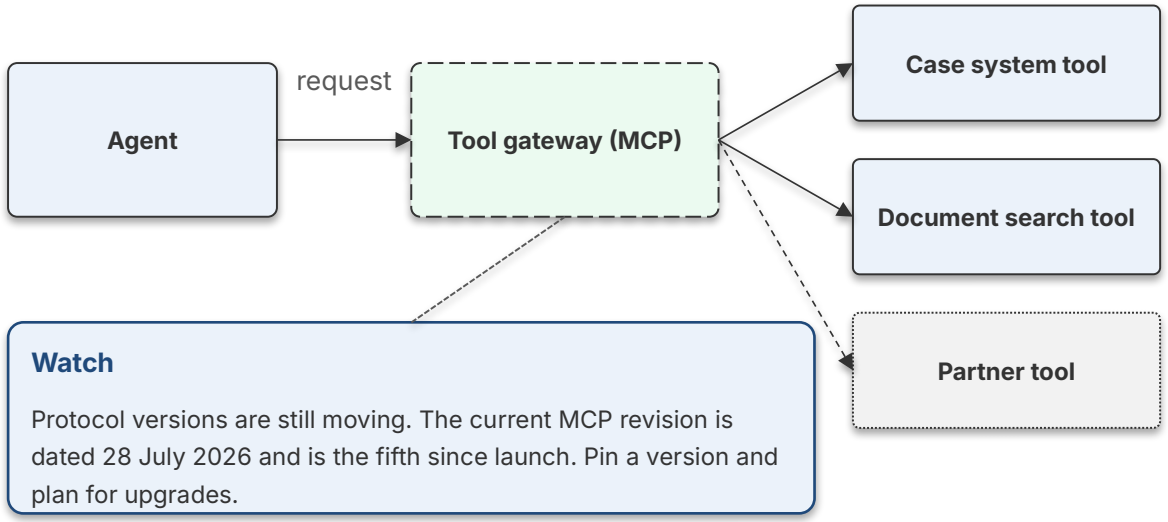
Data sensitivity	Hosted public model	Government-approved cloud, Canadian region	On-premises model
Public or unclassified, no personal information	Allowed	Allowed	Allowed
Internal, no personal information	Case by case	Allowed	Allowed
Personal information or Protected A or B	No	Allowed after a privacy and security review	Allowed
Higher than Protected B	No	No	Only on approved infrastructure

Check before you rely on this

— This grid is a starting position for the Board. Confirm each cell with departmental security and privacy officers and current Treasury Board direction.

Source: Enterprise Architecture. Judgment: this is my read, not a published standard.

Agents reach systems only through a tool gateway



The gateway swaps the agent's token for a short-lived, narrow token for each tool. The tool never sees the agent's own credentials.
Read tools run freely. Tools that change records or send messages wait for a person to approve.

Application Technology External (out of scope)

Figure 3 — Agent tool access through a gateway

What the standard gives us

- The Model Context Protocol (MCP) is an open standard for how AI applications connect to tools and data.
- Servers expose tools, resources and prompts over JSON-RPC.
- Governance moved to the Linux Foundation's Agentic AI Foundation in December 2025.
- A standard interface means one gateway can control many tools. The control is ours to build.

Source: O'Reilly Radar, "The interfaces are arriving" (2026); MCP specification dated 2026-07-28.

4

Governance and risk

How the architecture meets federal direction and a recognised risk framework.

GOVERNANCE

NIST functions map to controls we can build

NIST function	What it asks	Federal instrument	Architecture control
Govern	Policy, roles and accountability, across all systems	Guide on the use of generative AI	AI governance board; named owner per system
Map	Context, purpose and who is affected	Algorithmic Impact Assessment	Use-case intake with risk tier
Measure	Test accuracy, bias and robustness	Directive testing and monitoring requirements	Evaluation harness in the platform
Manage	Treat risk, monitor, respond	Directive: ongoing monitoring and review	Gateway logs, alerts, rollback

What NIST is and is not

— The AI RMF is voluntary and not certifiable. Govern runs across the other three. Map, Measure and Manage repeat for each system. The mapping to federal instruments is my reading and needs policy review.

Source: NIST AI RMF 1.0 (Jan 2023) and Generative AI Profile, NIST AI 600-1 (Jul 2024). TBS guide and Directive via canada.ca.

GOVERNANCE

Each FASTER principle has a home in the design

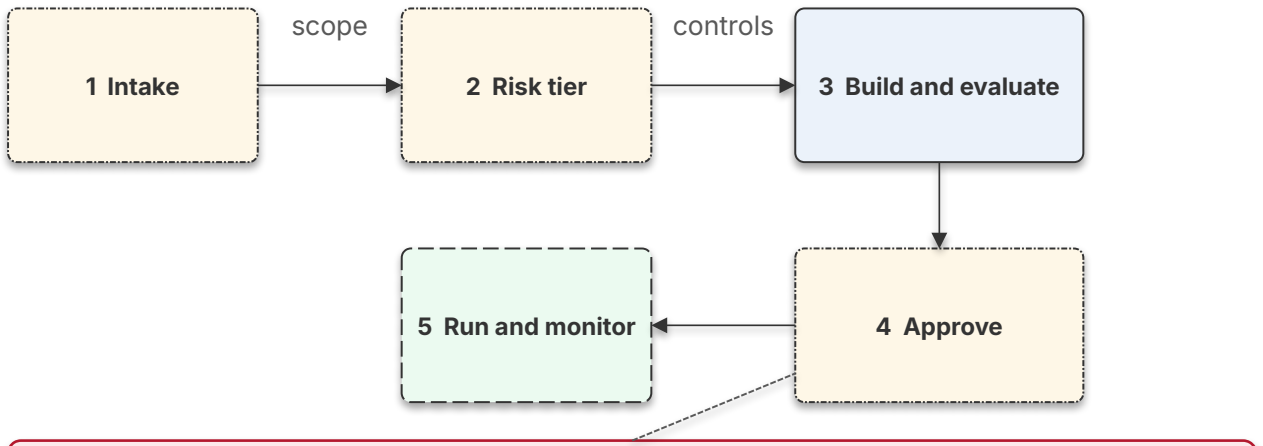
Principle	In plain words	Where the architecture delivers it
Fair	Do not discriminate. Test for bias	Evaluation harness; AIA fairness questions
Accountable	A person answers for each use	Named owner in the registry; human sign-off
Secure	Protect data and the model	Gateway, scoped tokens, hosting grid
Transparent	Say when AI is used and how	Notice on the channel; published AIA; call logs
Educated	Staff know the limits	Training before access is granted
Relevant	AI fits a real need	Intake step asks what problem is being solved

Scope

— FASTER is the set of principles Treasury Board Secretariat asks institutions to align with for generative AI. The right-hand column is my mapping.

Source: Treasury Board of Canada Secretariat, Guide on the use of generative AI (canada.ca).

Every use case passes the same five gates



Gate 2 assigns risk tier A to D. Tier D (decisions about clients) gets the full assessment; tier A a short form.

Gate 5 never closes. Monitoring goes back to gate 2, and a change of scope sends the use case round again.

Business Application Technology

Figure 4 — Use-case lifecycle and approval gates

Why gates, not a committee

— A fixed path means a low-risk drafting aid does not wait in the same queue as a benefits decision.

— The Directive covers systems that fully or partly automate an administrative decision. Gate 2 decides if it applies.

— Steps 3 to 5 are covered by the platform, so project teams do not rebuild them.

Source: Treasury Board Directive on Automated Decision-Making and Algorithmic Impact Assessment (canada.ca).

RULES

Each principle has a rule that enforces it

Principle	Rule	Shown in scenario
Data stays put	No source is indexed above the tier limit of the use case	RAG
One front door	Pinned model versions; re-evaluate before any change	New model
Rights travel	Tokens are narrowed to the user, never passed on	User and system rights; new tool
People decide	Actions that change things need approval; proposed second approver for tier D	Actions; incidents
Swap the model	A kill switch and rollback path exist before go-live	Incidents; new model

Status

— The second approver for tier D is a proposal for the Board, not a published requirement.

Source: Enterprise Architecture; companion decks on AI risk and scenarios. Judgment: this is my read, not a published standard.

Reuse the controls, not the model. Models will change; the gateway, the rights checks and the approval path should not.

5

Adopting it

A staged path, and the decisions the Board needs to make.

ROADMAP

Three stages, each useful on its own

Stage	Timing	What is delivered	Exit test
1 Foundations	First 6 months	AI gateway, use-case registry, risk tiers A to D, evaluation harness, kill switch, hosting grid	Every call is logged; no new model is approved without an evaluation report
2 Shared services	Months 6 to 18	Retrieval service and index with rights tests, tool gateway, approval workflow, evidence register	Two teams reuse retrieval; a rights test fails any index above its tier
3 Scale and assure	Months 18 to 36	Agents on registered tools, continuous monitoring, internal model hosting where needed	An audit can trace any answer to its sources and approver

Timing

— Durations are planning assumptions for discussion, not commitments. Funding and staffing are not assessed here.

Source: Enterprise Architecture. Judgment: this is my read, not a published standard.

DECISIONS

What is settled and what the Board decides

Settled by the architecture

— All model calls go through one gateway

— Rights are checked at retrieval

— Agents act through registered tools only

— Use cases are tiered before build

— Every call is logged

Needs a Board decision

— Which hosting options are approved at each sensitivity level

— Who owns the gateway and the index

— Which human approvals tools need

— How long call logs are kept

— Which model providers are on the list

Source: Enterprise Architecture. Judgment: this is my read, not a published standard.

6

Appendix: the reference model

What a reference model is, what it is for, and how a use case benefits.

APPENDIX

What a reference model is

What it is

A shared, technology-neutral pattern: the parts, how they connect, and the rules they follow.

What it contains

Layers, a control plane, principles, rules, risk tiers, approval gates and a roadmap.

What it is for

Gives every project the same starting point, the same controls and the same words.

What it is not

Not a product list, not a project design and not a standard. Solutions still need their own architecture.

Source: Enterprise Architecture. Judgment: this is my read, not a published standard.

APPENDIX

How a use case benefits from the model

Without a reference model

— Each team picks its own model and keys
— Data is copied into new stores
— Risk is judged differently each time
— Approvals start from zero
— An audit rebuilds the story by hand

With the reference model

— Teams reuse the gateway and services
— Rights are checked at retrieval
— Risk tier A to D sets the controls
— Approval follows a fixed path
— Evidence is kept as work proceeds

Source: Enterprise Architecture; see the AI risk addendum and scenarios decks. Judgment: this is my read, not a published standard.

SOURCES

Where each claim comes from

Federal direction

Guide on the use of generative AI
FASTER principles and policy considerations

Directive on Automated Decision-Making
Assessment before production

Algorithmic Impact Assessment
Impact levels set required controls

Frameworks and standards

NIST AI Risk Management Framework
Govern, Map, Measure, Manage; AI 600-1 profile

O'Reilly: The interfaces are arriving
MCP governance and 2026 revision

Model Context Protocol
The specification itself

Links checked 4 November 2026 from search results; the NIST and MCP home pages were not opened.